
COMPTE RENDU DU TP DE CYBERSECURITE

TP 4.1 — Mise en place d'un pare-feu pfSense et segmentation du laboratoire

Objectifs du TP

Ce travail pratique a pour but de transformer un laboratoire réseau totalement ouvert en un réseau contrôlé et segmenté grâce à l'installation et la configuration d'un pare-feu pfSense.

➤ Architecture mise en place

Le laboratoire virtuel est composé des machines suivantes :

- Kali Linux : machine attaquante (réseau WAN / NAT)
- Ubuntu : serveur (réseau LAN / Host-Only)
- Windows : poste utilisateur (réseau LAN / Host-Only)
- PfSense : pare-feu placé entre le LAN et le WAN

➤ Configuration réseau des machines virtuelles

• Machine pfSense

Interface WAN (carte 1) : Mode NAT : accès Internet simulé

Interface LAN (carte 2) : Mode Host-Only : réseau interne isolé

Adresse IP LAN : 192.168.1.1 / 24

```
WAN (wan)      -> em0      -> v4/DHCP4: 10.0.2.15/24
LAN (lan)      -> em1      -> v4: 192.168.1.1/24

0) Logout (SSH only)          9) pfTop
1) Assign Interfaces          10) Filter Logs
2) Set interface(s) IP address 11) Restart webConfigurator
3) Reset webConfigurator password 12) PHP shell + pfSense tools
4) Reset to factory defaults  13) Update from console
5) Reboot system              14) Enable Secure Shell (sshd)
6) Halt system                 15) Restore recent configuration
7) Ping host                   16) Restart PHP-FPM
8) Shell
```

• Machine Ubuntu (serveur)

Interface réseau : Host-Only — même réseau que pfSense LAN

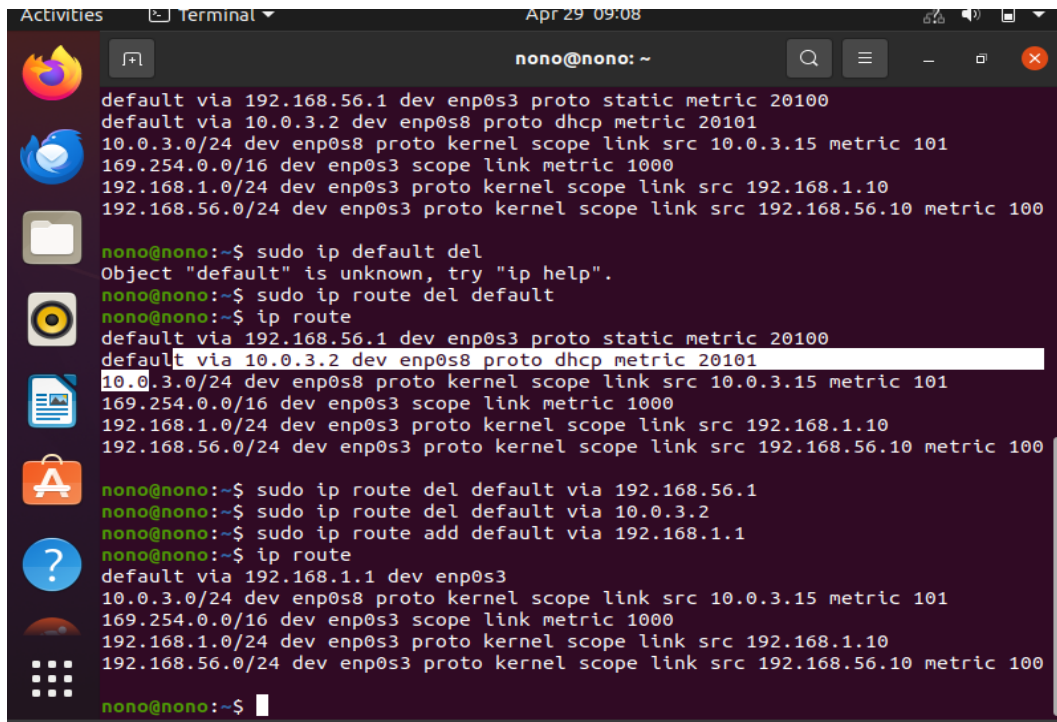
Adresse IP : 192.168.1.10 / 24 **Passerelle**

: 192.168.1.1 (pfSense)

Commandes de configuration utilisées :

```
sudo ip addr add 192.168.1.10/24 dev enp0s3
```

```
sudo ip route add default via 192.168.1.1
```



The screenshot shows a terminal window titled 'Terminal' with the prompt 'nono@nono: ~'. The user has entered several commands to configure the network. The output shows the current routing table with a default route via 192.168.56.1. The user then deletes this route and adds a new default route via 192.168.1.1. The final output shows the updated routing table with the new default route.

```
default via 192.168.56.1 dev enp0s3 proto static metric 20100
default via 10.0.3.2 dev enp0s8 proto dhcp metric 20101
10.0.3.0/24 dev enp0s8 proto kernel scope link src 10.0.3.15 metric 101
169.254.0.0/16 dev enp0s3 scope link metric 1000
192.168.1.0/24 dev enp0s3 proto kernel scope link src 192.168.1.10
192.168.56.0/24 dev enp0s3 proto kernel scope link src 192.168.56.10 metric 100

nono@nono:~$ sudo ip default del
Object "default" is unknown, try "ip help".
nono@nono:~$ sudo ip route del default
nono@nono:~$ ip route
default via 192.168.56.1 dev enp0s3 proto static metric 20100
default via 10.0.3.2 dev enp0s8 proto dhcp metric 20101
10.0.3.0/24 dev enp0s8 proto kernel scope link src 10.0.3.15 metric 101
169.254.0.0/16 dev enp0s3 scope link metric 1000
192.168.1.0/24 dev enp0s3 proto kernel scope link src 192.168.1.10
192.168.56.0/24 dev enp0s3 proto kernel scope link src 192.168.56.10 metric 100

nono@nono:~$ sudo ip route del default via 192.168.56.1
nono@nono:~$ sudo ip route del default via 10.0.3.2
nono@nono:~$ sudo ip route add default via 192.168.1.1
nono@nono:~$ ip route
default via 192.168.1.1 dev enp0s3
10.0.3.0/24 dev enp0s8 proto kernel scope link src 10.0.3.15 metric 101
169.254.0.0/16 dev enp0s3 scope link metric 1000
192.168.1.0/24 dev enp0s3 proto kernel scope link src 192.168.1.10
192.168.56.0/24 dev enp0s3 proto kernel scope link src 192.168.56.10 metric 100

nono@nono:~$
```

- **Machine Windows (poste utilisateur)**

Interface réseau : Host-Only

Adresse IP : 192.168.1.20

Masque de sous-réseau : 255.255.255.0

Passerelle : 192.168.1.1

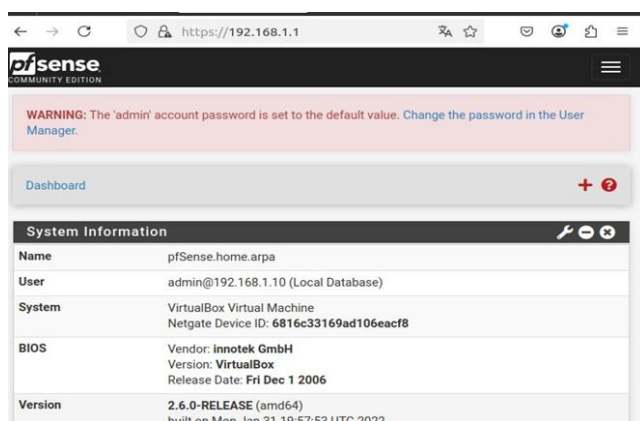
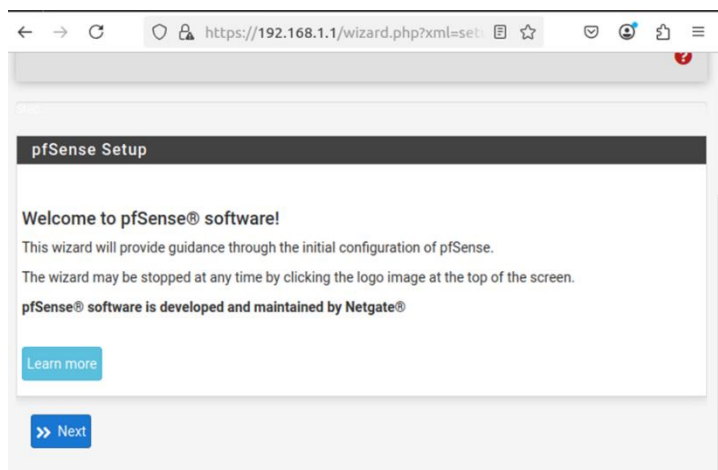
➤ **Accès et navigation dans l'interface web pfSense**

L'interface web d'administration de pfSense est accessible depuis Ubuntu ou Windows à l'adresse suivante :

https://192.168.1.1

Identifiant : admin

Mot de passe : pfsense



➤ Vérification du routage (Étape 8)

Depuis Ubuntu, test d'accès à Internet via pfSense : `ping 8.8.8.8`

```
nono@nono:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=254 time=153 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=254 time=211 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=254 time=231 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=254 time=254 ms
64 bytes from 8.8.8.8: icmp_seq=5 ttl=254 time=144 ms
^C
```

Interprétation : Le ping réussit, ce qui confirme que pfSense route correctement le trafic et que l'architecture WAN/LAN est opérationnelle.

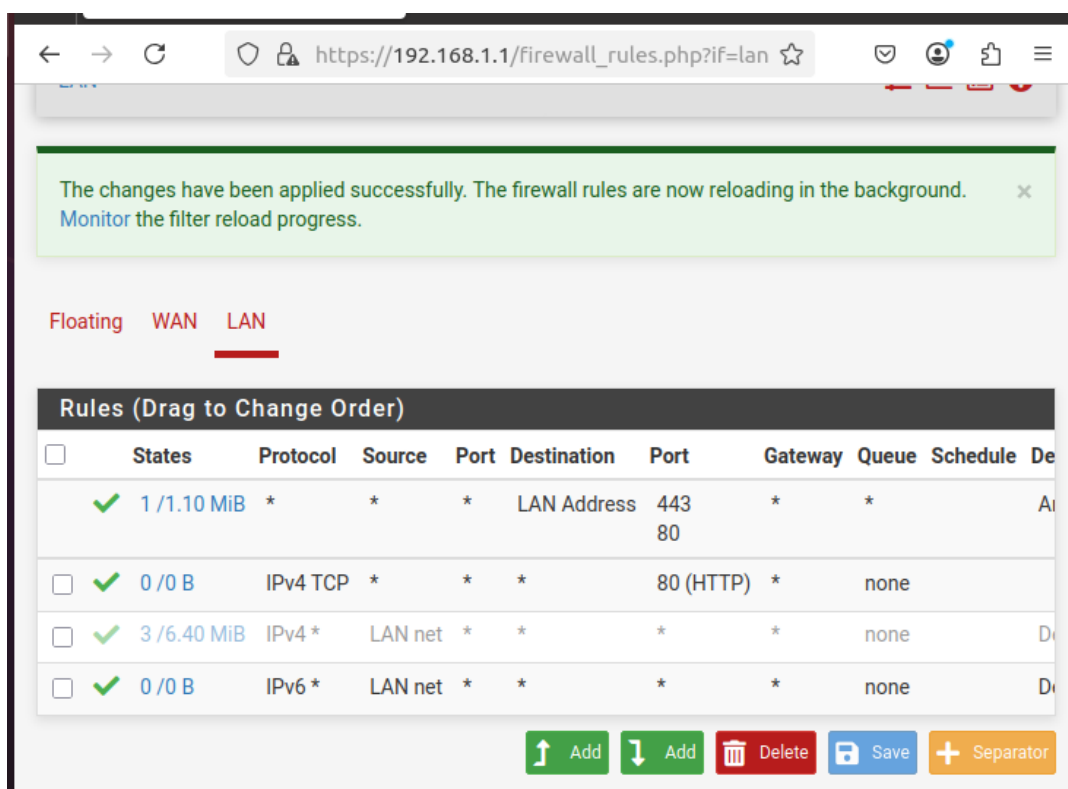
➤ Mise en place de la règle de filtrage (Étape 9)

Dans interface pfSense : Firewall → Rules → LAN

Étape 1 : Désactivation de la règle par défaut qui autorise tout le trafic

Étape 2 : Création d'une nouvelle règle avec les paramètres suivants :

Paramètre	Valeur
Action	Pass (Autoriser)
Interface	LAN
Protocole	TCP
Port de destination	80 (HTTP)
Description	Autoriser uniquement HTTP depuis le LAN



➤ Explication de la règle

La règle créée fonctionne de la manière suivante :

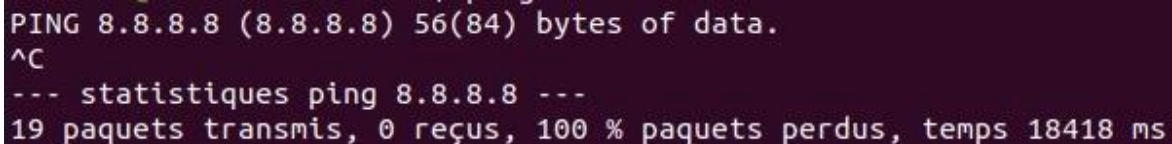
- Elle AUTORISE : le trafic TCP à destination du port 80 (HTTP) depuis le réseau LAN
- Elle BLOQUE : tout autre type de trafic non explicitement autorisé (ICMP, UDP, autres ports TCP...)
- Principe appliqué : deny by default — tout ce qui n'est pas autorisé est refusé

➤ Tests de fonctionnement (Étape 10)

- Test HTTP — trafic autorisé : `curl http://example.com`

Observation : La requête HTTP aboutit correctement. pfSense laisse passer le trafic sur le port 80.

Test ICMP — trafic bloqué `ping 8.8.8.8`



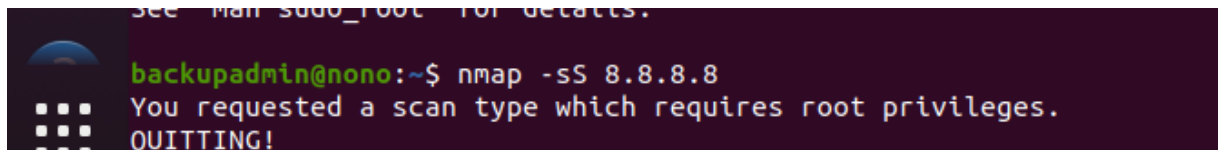
```
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.  
^C  
--- statistiques ping 8.8.8.8 ---  
19 paquets transmis, 0 reçus, 100 % paquets perdus, temps 18418 ms
```

Observation : Le ping échoue. pfSense bloque le protocole ICMP car il n'est pas autorisé par la règle.

➤ Simulation d'un comportement attaquant

Depuis Ubuntu (machine compromise), tentative de scan réseau :

`nmap -sS 8.8.8.8`



```
See man sudo_root for details.  
backupadmin@nono:~$ nmap -sS 8.8.8.8  
You requested a scan type which requires root privileges.  
QUITTING!
```

Résultat : Le scan ne fonctionne pas correctement. pfSense bloque les communications non autorisées, empêchant les communications vers un serveur de commande et les scans réseau externes.

➤ Propositions d'améliorations

À la suite de ce TP, plusieurs améliorations peuvent être envisagées pour renforcer la sécurité de l'architecture :

- Autoriser HTTPS uniquement (port 443)

Plutôt qu'autoriser HTTP (port 80, non chiffré), il est préférable de créer une règle Pass TCP sur le port 443 (HTTPS) afin de garantir la confidentialité des échanges. Le port 80 devrait être bloqué ou redirigé vers HTTPS.

Rules (Drag to Change Order)										
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	D
☒	✓ 0 / 271 KiB	*	*	*	LAN Address	443 80	*	*		
☐	✓ 0 / 0 B	IPv4 *	LAN net	*	*	*	*	none		
☐	✓ 0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		
☐	✓ 0 / 0 B	IPv4 TCP	*	*	*	443 (HTTPS)	*	none		

- Bloquer des ports spécifiques à risque

Des ports couramment exploités par les attaquants devraient être explicitement bloqués : port 23 (Telnet), port 21 (FTP non sécurisé), ports 135-139 (NetBIOS), port 445 (SMB). L'approche recommandée est le principe du moindre privilège : tout bloquer par défaut et n'ouvrir que les ports strictement nécessaires.

☐	✓ 0 / 0 B	IPv4 TCP	*	*	*	443 (HTTPS)	*	none	
☐	✗ 0 / 0 B	IPv4 TCP	*	*	*	21 (FTP)	*	none	
☐	✗ 0 / 0 B	IPv4 TCP	*	*	*	23 (Telnet)	*	none	

- Ajouter une zone DMZ

Une zone démilitarisée (DMZ) peut être créée comme troisième interface réseau sur pfSense. Les serveurs accessibles depuis Internet (serveur web, serveur mail) y seraient placés, isolés du LAN interne. Cela limite la propagation d'une attaque : si un serveur en DMZ est compromis, l'attaquant ne peut pas atteindre directement le réseau interne.

Conclusion

Ce travail pratique a permis de mettre en évidence plusieurs principes fondamentaux de la cybersécurité réseau :

- La sécurité commence par le réseau : un réseau non segmenté est une cible facile
- Un pare-feu bien configuré limite fortement les possibilités d'attaque
- Même si une machine est compromise, le pare-feu peut empêcher l'exfiltration de données et les communications avec un C2